

# Аудит IT-инфраструктуры проекта партнёра

## 1. Описание предприятия

В данной работе моделируется деятельность IT-компании (проектная команда и контур эксплуатации), выполняющей для партнёра внедрение или масштабную модернизацию информационной системы. Моделирование во многом опирается на материалы, которые студент подготовил в ходе выполнения учебных заданий: в них последовательно раскрыты конкурентный контекст и SLA, процессы ITIL, метрики мониторинга и финансовая модель. В текстах студент неоднократно указывает контекст вуза и дополнительного образования; для приземления модели на конкретную организацию в настоящем документе за основу взяты Воронежский государственный университет (ВГУ) и условное подразделение дополнительного образования в его структуре (без претензии на официальное описание реальной инфраструктуры ВГУ без отдельного согласования).

Чтобы смоделировать систему и закрыть формальные поля методических требований при отсутствии полного паспорта объекта, сделан ряд учебных допущений — они помечены ниже и должны быть заменены фактическими данными при появлении доступа к штатному расписанию и договорам партнёра.

| Параметр                         | Допущение для расчётов и аудита                                                                     | Проверка на объекте |
|----------------------------------|-----------------------------------------------------------------------------------------------------|---------------------|
| Масштаб вуза (все подразделения) | условно 2–5 тыс. сотрудников и обучающихся в совокупности (типичный порядок для регионального вуза) | штатное расписание  |
| Подразделение ДО (штат)          | условно 8–20 сотрудников, пользователей ИС ДО — основная масса этого штата                          | приказ о штате      |
| Проектная / IT-команда внедрения | условно 0,3–1,0 FTE сопровождения после запуска + волнообразная разработка                          | договор/смета       |

Также для большего понимания контекста проекта и предприятия были построены диаграммы.

Use Case — автоматизация дополнительного образования

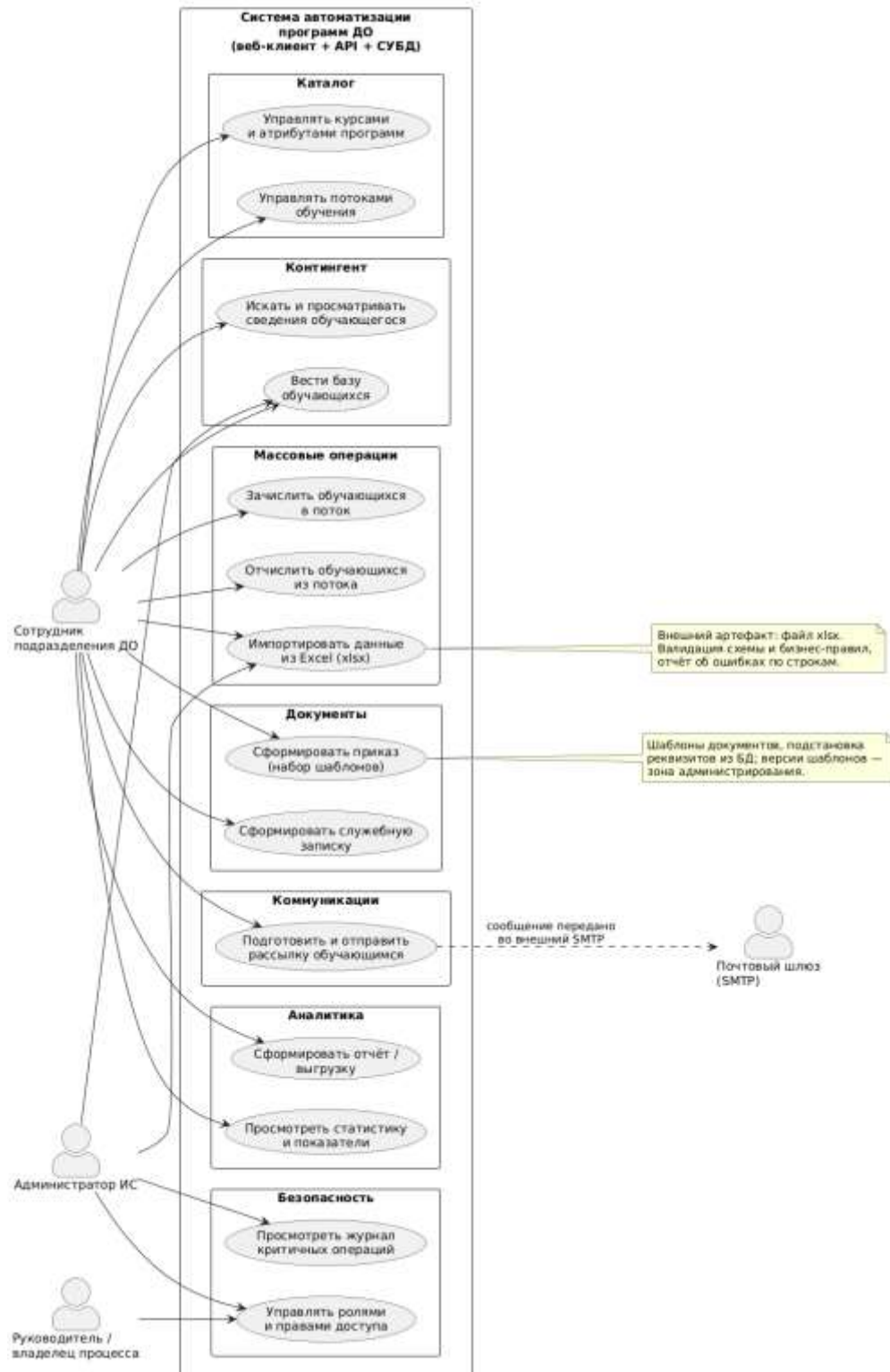


Рисунок 1 - Use Case

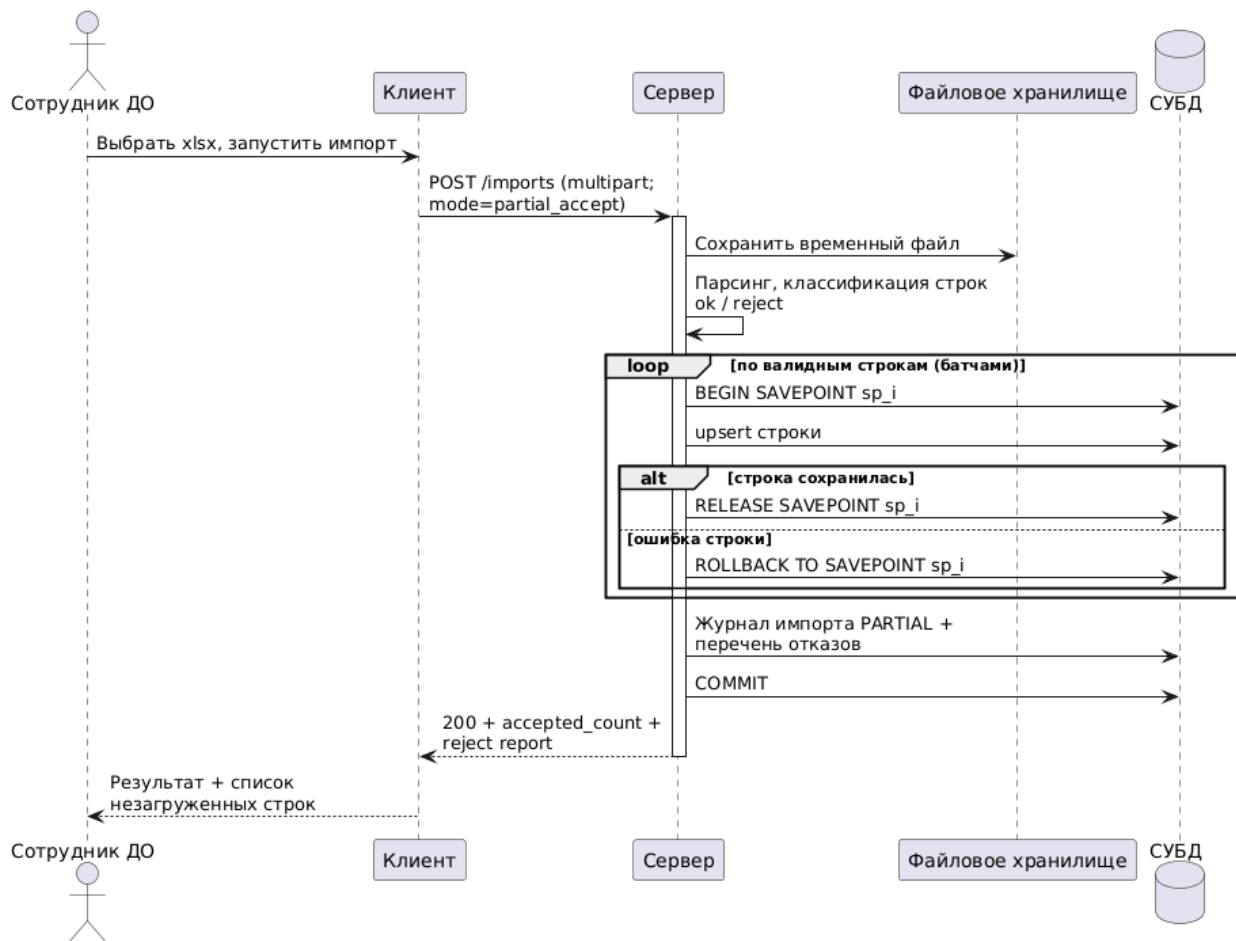


Рисунок 2 - Диаграмма взаимодействия - импорт xlsx

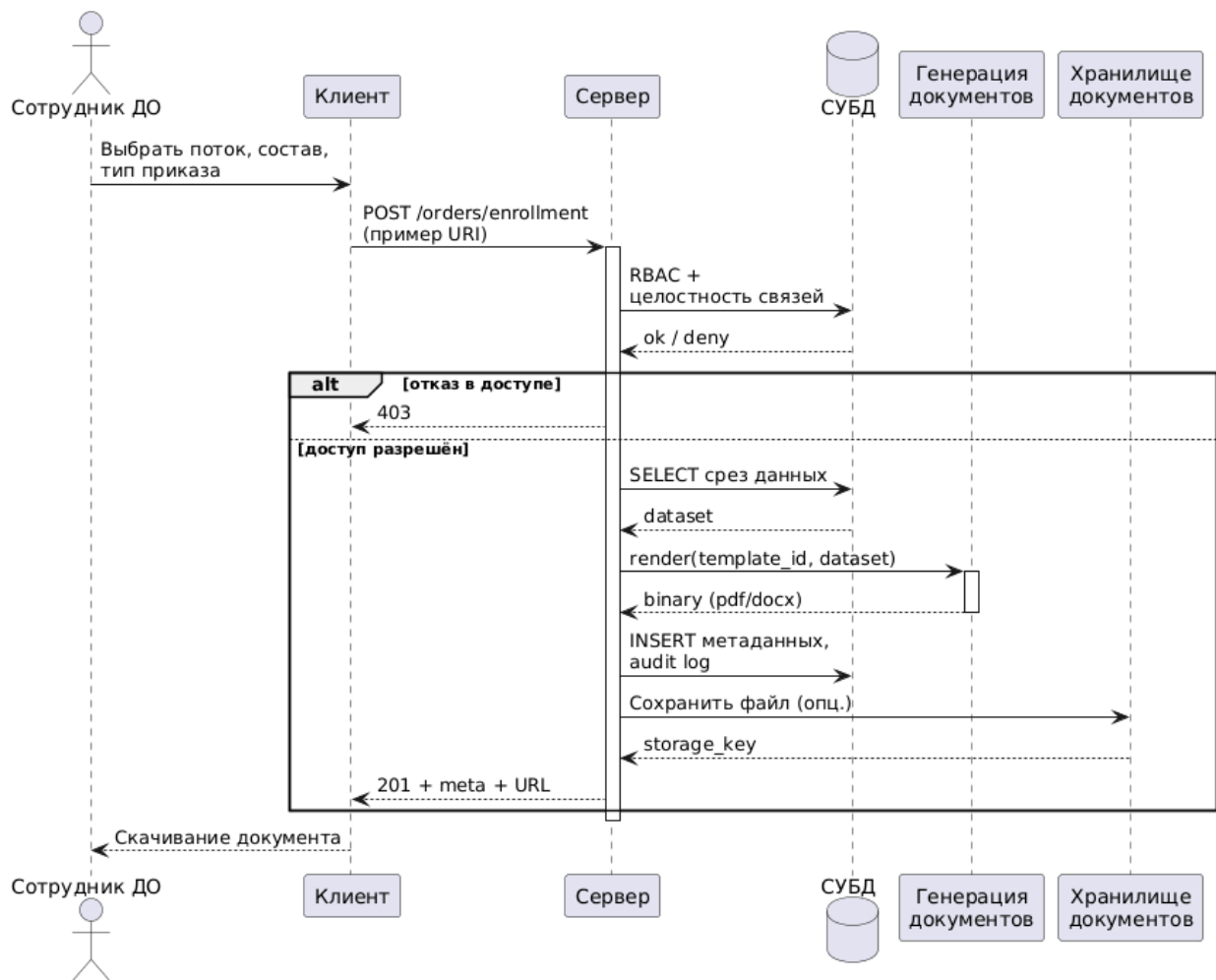


Рисунок 3 - Диаграмма взаимодействия - формирование приказа о зачислении

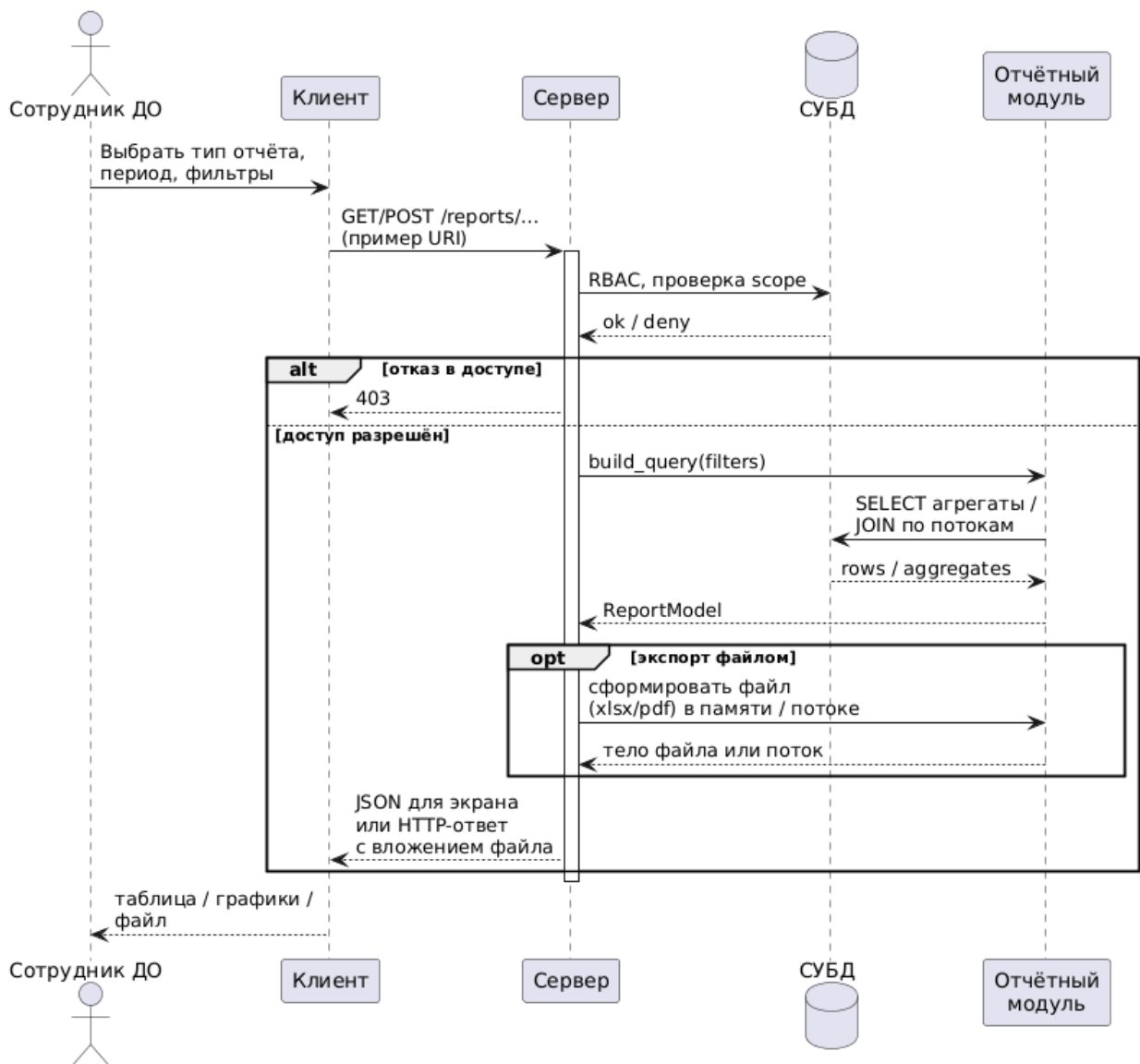


Рисунок 4 - Диаграмма взаимодействия - формирование отчёта / оперативная статистика

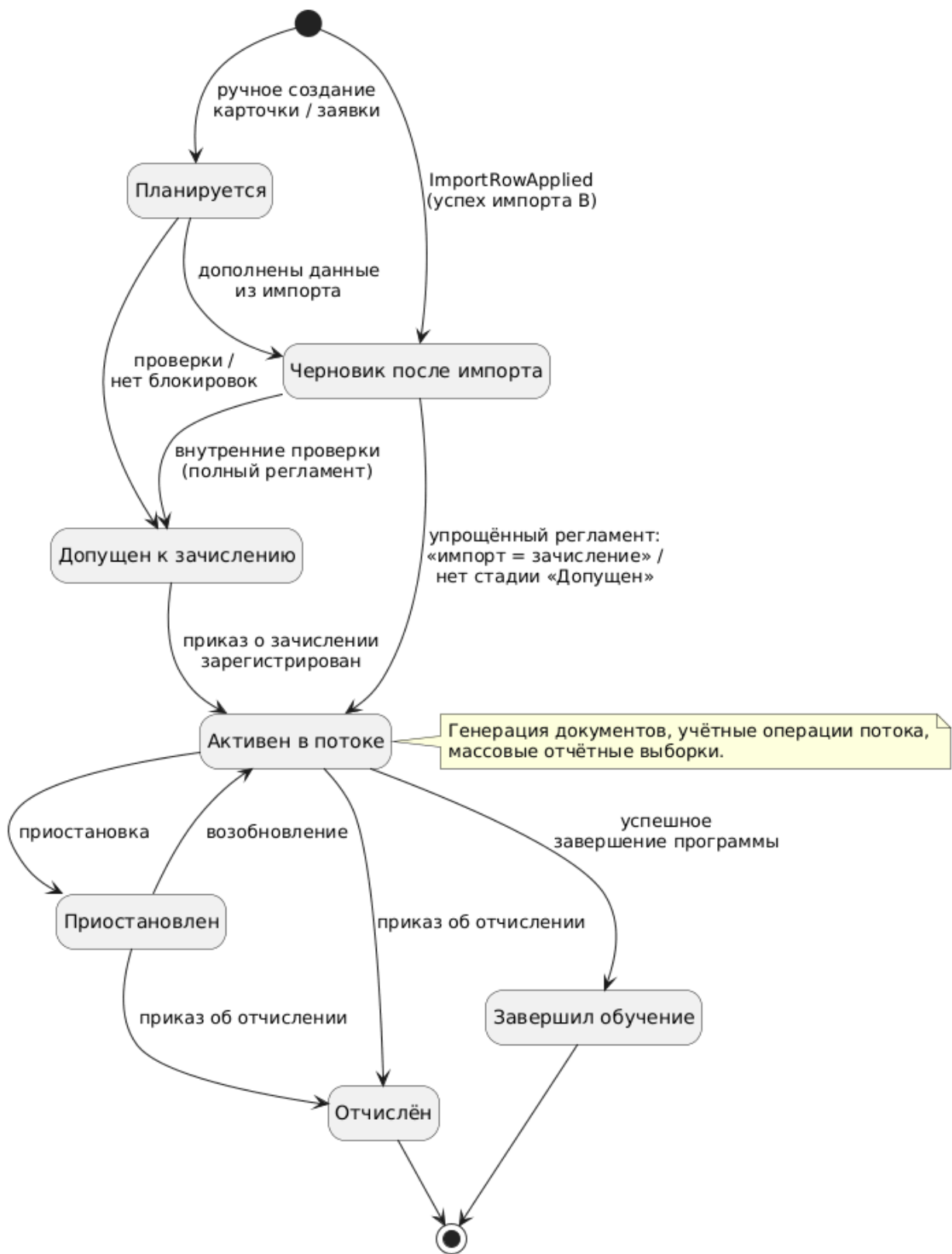


Рисунок 5 - Диаграмма состояний - участие обучающегося в потоке ДО

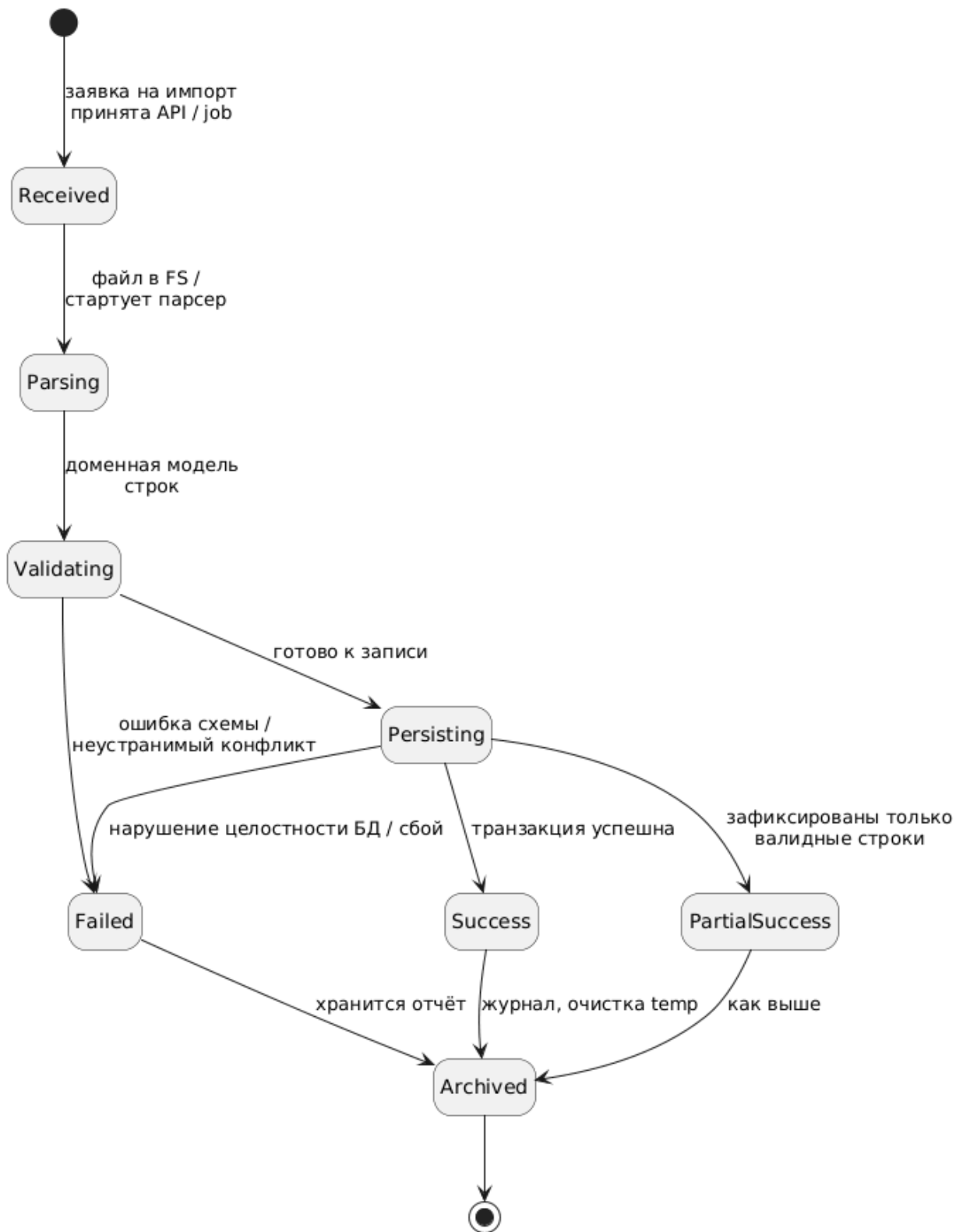


Рисунок 6 - Диаграмма состояний - импорт

## 1.1. Общая информация

Контекст аудита: смоделирована ИТ-организация, выполняющая проект партнёра — внедрение/масштабную модернизацию веб-сервиса автоматизации административных процессов дополнительного образования (ДО). Описание синтезировано из решений задач 1–4 и диаграмм (варианты использования, взаимодействия, состояния).

Риск аудита (недостаток исходных данных): в учебных материалах нет фактических сведений о серийных номерах оборудования, моделях ЦОД, точных версиях ОС на каждой машине, схеме VLAN, отчётах по pen-test, журналах инцидентов и действующих локальных нормативных актах вуза. Ниже приведена логически согласованная модель; места, требующие подтверждения на объекте, отмечены явно.

| Параметр                                         | Значение (по материалам проекта)                                                                  | Комментарий аудитора                                                                                             |
|--------------------------------------------------|---------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| <b>Условное название ИТ-команды / подрядчика</b> | Проектная группа внедрения (в т.ч. роли: разработчик, DevOps, администратор ИС, менеджер проекта) | Из решения задачи 2 (RACI, ITIL-процессы). Юридическая форма не зафиксирована — это риск границ ответственности. |
| <b>Партнёр (заказчик эксплуатации)</b>           | Подразделение ВГУ, ведущее программы дополнительного образования                                  | Из решения задачи 1 и решения задачи 4.                                                                          |
| <b>Сфера деятельности партнёра</b>               | Образовательные услуги (ДО), администрирование контингента, документооборот                       | —                                                                                                                |
| <b>Размер (число сотрудников)</b>                | См. таблицу учебных допущений выше; в исходных заданиях точная численность не задана              | Заменить допущения фактическими цифрами при доступе к штатному расписанию партнёра.                              |

## 1.2. Основные бизнес-процессы, зависящие от ИТ (не менее трёх)

- Ведение контингента и учёт статуса в потоке** — карточки обучающихся, поиск, связь с курсами/потоками; состояния жизненного цикла по диаграмме состояний (в т.ч. черновики).
- Массовый ввод и актуализация данных** — импорт из Excel (xlsx): на диаграммах взаимодействий заданы вариант частичного принятия строк; на диаграмме состояний импорта, отражены синхронная упрощённая модель и целевая декомпозиция с хранилищем и политиками записи.
- Документооборот по зачислению/отчислению** — генерация приказов и служебных записок (диаграммы взаимодействий, сценарий генерации приказа).



4. **Аналитика и отчётность** — параметрические отчёты и просмотр статистики как отдельные сценарии (диаграмма вариантов использования); на уровне последовательностей выделен слой RPT (диаграммы взаимодействий, сценарий формирования отчёта и сводных показателей).
5. **Коммуникации с обучающимися** — подготовка и отправка рассылок, транспорт через почтовый шлюз SMTP вне контура приложения.
6. **Управление доступом и аудит** — роли, матрица прав; наблюдаемость.

### 1.3. Роль IT в бизнесе

- **Как IT поддерживает процессы:** единая точка правды по контингенту и потокам; сокращение ручного копирования из таблиц (бизнес-проблемы и эффекты — решение задачи 4); обеспечение измеримых SLA по доступности и времени операций (решение задачи 1, решение задачи 2).
- **Основные IT-системы по процессам** (см таблицу ниже).
- **Как участвуют:** первая колонка — презентация и правила; вторая — данные и хранение; интеграции — файлы и SMTP.

| Бизнес-процесс                  | IT-система 1                                    | IT-система 2                           | Участие в процессе                                                                                                                                                      |
|---------------------------------|-------------------------------------------------|----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Контингент и статусы            | Веб-приложение (React UI + FastAPI)             | Реляционная СУБД                       | UI/API обеспечивают сценарии и переходы состояний; СУБД хранит сущности слушатель–поток, статусы, аудит.                                                                |
| Импорт и качество данных        | Backend API (импорт, в т.ч. частичное принятие) | Файловое хранилище (FS) (xlsx) + СУБД  | API выполняет парсинг, валидацию, построчные транзакции; FS — временный артефакт; БД — целевая запись и журнал импорта.                                                 |
| Документы                       | Подсистема генерации (DOC)                      | СУБД + хранилище файлов                | DOC рендерит шаблон; метаданные и ссылки на файлы — в БД/FS.                                                                                                            |
| Аналитика                       | Слой отчётности (RPT) + API                     | СУБД                                   | RPT строит агрегаты/выгрузки; опциональный экспорт в файл через FS.                                                                                                     |
| Коммуникации                    | Модуль рассылок в приложении                    | Почтовый шлюз (SMTP) организации       | Приложение формирует адресатов и тело; доставку выполняет внешний SMTP.                                                                                                 |
| Эксплуатация и качество сервиса | Мониторинг, алертинг                            | Тикет-система, среда исполнения (Host) | Сбор метрик из логов, nginx, heartbeat; реакция админа; перезапуск/откат на уровне хоста/оркестратора (решение задачи 2, решение задачи 3; отдельная последовательность |

| Бизнес-процесс | IT-система 1 | IT-система 2 | Участие в процессе                                                                |
|----------------|--------------|--------------|-----------------------------------------------------------------------------------|
|                |              |              | на диаграммах взаимодействий не обязательна, если процесс закреплён регламентом). |

- **Использование:** пользователи ДО работают через браузер; интеграция с внешним миром — файлы Excel, SMTP для рассылок; средства мониторинга через различные каналы, выводятся на дашборды.

#### 1.4. (Задача со звёздочкой) Мониторинг IT-систем: метрики, пороги, алерты

Данные перенесены из решения задачи 3 (согласованы с SLA в решении задачи 1 / решении задачи 2).

**Трактовка для формального соответствия ТЗ:** в блоке процессов фигурируют разные ИТ-компоненты (СУБД, тикеты, хранилище). Чтобы не смешивать «служебный шум» с прикладными KPI, в отчёте зафиксированы наблюдаемые сервисы: (1) приложение/API, (2) контур импорта как сквозной сценарий, (3) генерация документов, плюс отдельно ниже — минимум по СУБД, тикетам и object storage, как того требует строгое прочтение «на каждую систему».

##### *А. Платформа приложения (доступность + API)*

| Метрика                          | Порог «норма»         | Предупреждение | Критично | Алерт / действие                                                                 |
|----------------------------------|-----------------------|----------------|----------|----------------------------------------------------------------------------------|
| Доступность сервиса              | $\geq 99\%$ за период | $< 99\%$       | $< 97\%$ | Уведомление администратору и техкоманде; при критическом — регистрация инцидента |
| Среднее время отклика API        | $\leq 2$ с            | $> 2,5$ с      | $> 4$ с  | Анализ нагрузки и «тяжёлых» маршрутов                                            |
| Доля HTTP 5xx / серверных ошибок | $\leq 1\%$            | $> 2\%$        | $> 5\%$  | Разбор логов, приоритизация дефектов                                             |

##### *Б. Сценарий импорта Excel (сквозной процесс, не только «HTTP 200»)*

| Метрика                | Порог «норма»              | Предупреждение | Критично  | Алерт / действие                           |
|------------------------|----------------------------|----------------|-----------|--------------------------------------------|
| Доля успешных импортов | $\geq 98\%$                | $< 98\%$       | $< 95\%$  | Проверка шаблонов и правил валидации       |
| Среднее время          | $\leq 60$ с (типовой файл) | $> 75$ с       | $> 120$ с | Оптимизация обработки, БД, размеров файлов |

| Метрика                                                                                        | Порог «норма»                                                 | Предупреждение | Критично      | Алерт / действие                                               |
|------------------------------------------------------------------------------------------------|---------------------------------------------------------------|----------------|---------------|----------------------------------------------------------------|
| импорта                                                                                        |                                                               |                |               |                                                                |
| Ошибки валидации на 1000 обработанных строк / доля файлов, отклонённых целиком (строгий режим) | $\leq 5$ откл./1000 строк; доля отклонённых файлов $\leq 2\%$ | Выше порога    | Массовый рост | Анализ шаблонов xlsx, обучение пользователей, доработка правил |

*Примечание:* показатель «критичные инциденты за неделю» из решения задачи 3 относится к эксплуатации сервиса в целом; в блоке импорта осмысленнее импорт-специфичная метрика качества данных (строгое отклонение файла vs частичное принятие).

#### *В. Генерация документов (приказы / служебные)*

| Метрика                                      | Порог «норма» | Предупреждение | Критично | Алерт / действие                                 |
|----------------------------------------------|---------------|----------------|----------|--------------------------------------------------|
| Доля успешной генерации                      | $\geq 99\%$   | $< 99\%$       | $< 96\%$ | Проверка шаблонов и входных данных               |
| Среднее время генерации                      | $\leq 30$ с   | $> 40$ с       | $> 60$ с | Профилирование генератора                        |
| Время восстановления после сбоя (процессное) | $\leq 2$ ч    | $> 2$ ч        | $> 4$ ч  | Эскалация, контроль инцидента (решение задачи 3) |

#### *Г. СУБД (инфраструктурный слой)*

| Метрика                         | Порог «норма»                               | Предупреждение            | Критично       | Алерт / действие                    |
|---------------------------------|---------------------------------------------|---------------------------|----------------|-------------------------------------|
| Доступность/готовность инстанса | подключения успешны, нет рестартов вне окна | рост latency p95 запросов | отказ коннекта | Failover / восстановление из бэкапа |
| Ошибки соединения /             | в пределах базового уровня                  | рост счётчиков            | лавина ошибок  | Анализ запросов, индексы, изоляция  |

| Метрика                                          | Порог «норма»               | Предупреждение | Критично                | Алерт / действие                             |
|--------------------------------------------------|-----------------------------|----------------|-------------------------|----------------------------------------------|
| deadlock /<br>долгие<br>блокировки               |                             |                |                         |                                              |
| Задержка<br>репликации<br>(если<br>используется) | $\leq$ целевого окна<br>RPO | выше порога    | разрыв<br>синхронизации | Проверка сети<br>репликации,<br>переключение |

*Д. Тикет-система / реестр инцидентов*

| Метрика                                                                            | Порог «норма»                 | Предупреждение | Критично          | Алерт / действие                           |
|------------------------------------------------------------------------------------|-------------------------------|----------------|-------------------|--------------------------------------------|
| Backlog<br>нерешённых P1/P2                                                        | 0 в конце смены               | 1–2 висящих    | > 2               | Дополнительный<br>дежурный                 |
| Среднее<br>время<br>закрытия<br>инцидента<br>по<br>категории<br>«импорт/документы» | в пределах<br>внутреннего SLO | выше SLO       | существенный рост | Разбор процесса,<br>обучение               |
| Доля<br>инцидентов<br>в без<br>привязки<br>к<br>релизу/изменению                   | низкая                        | рост           | хаос<br>изменений | Усиление связи с RFC<br>(решение задачи 2) |

*Е. Object storage / файловое хранилище (артефакты.xlsx, экспорт)*

| Метрика                                       | Порог «норма»                | Предупреждение | Критично        | Алерт / действие                        |
|-----------------------------------------------|------------------------------|----------------|-----------------|-----------------------------------------|
| Успешность<br>операций<br>PUT/GET<br>(API S3) | $\geq 99,9\%$                | снижение       | массовые<br>5xx | Эскалация провайдеру /<br>проверка квот |
| Задержка<br>p95 для<br>GET<br>объектов        | в пределах SLA<br>приложения | рост           | таймауты        | Проверка региона/канала                 |

| Метрика                    | Порог «норма» | Предупреждение | Критично | Алерт / действие           |
|----------------------------|---------------|----------------|----------|----------------------------|
| Заполнение квоты хранилища | < 80%         | > 80%          | > 95%    | Очистка temp, политика TTL |

**Организационный KPI** «критичные инциденты за неделю» остаётся в решении задачи 3 на уровне общей устойчивости сервиса (дашборд блока «Пользовательский эффект»), а не как третья метрика только импорта.

**Источники данных:** heartbeat/доступность, логи API, APM, журналы импорта и генерации, тикет-система (решение задачи 3; реакция на инциденты и перезапуск на уровне инфраструктуры — в регламентах эксплуатации).

## 2. Инвентаризация IT-инфраструктуры

### 2.1. Аппаратное обеспечение

В задачах не было предложено сметы необходимых аппаратов. Ниже предлагается типовой перечень для развёртывания описанного стека (Linux-серверы приложений/БД, рабочие станции пользователей Windows, опционально object storage).

| № | Тип                                                                                            | Назначение                                           | ОС / среда исполнения (целевая / типовая)                                                   |
|---|------------------------------------------------------------------------------------------------|------------------------------------------------------|---------------------------------------------------------------------------------------------|
| 1 | Сервер приложений (VM/физический)                                                              | FastAPI, очереди/воркеры импорта при масштабировании | Linux (напр. Ubuntu LTS) — подтвердить на объекте                                           |
| 2 | Сервер СУБД (VM/физический) или управляемый RDS                                                | Реляционная БД                                       | Linux + СУБД (PostgreSQL и др. — не зафиксировано в решении задачи 1)                       |
| 3 | Хост/VM под S3-совместимое хранилище (MinIO, Ceph RGW или managed object storage у провайдера) | Временные xls/xlsx, экспорт, файлы документов        | Linux для self-hosted; для managed — N/A (SaaS), версия API S3 зафиксировать в конфигурации |
| 4 | Обратный прокси                                                                                | TLS, маршрутизация, лимиты                           | Linux (nginx и др.)                                                                         |
| 5 | BM/сервис мониторинга                                                                          | Prometheus/Grafana или облачный APM                  | Linux или managed                                                                           |
| 6 | Рабочая станция сотрудника ДО (×N)                                                             | Браузер, работа с Excel до загрузки                  | Windows 10/11                                                                               |
| 7 | Рабочая станция администратора ИС                                                              | Админ-консоль, доступ к логам/дашбордам              | Windows / Linux                                                                             |
| 8 | BM под CI/CD (опционально)                                                                     | Сборка, тесты, деплой                                | Linux                                                                                       |

| №  | Тип                                                                         | Назначение                          | ОС / среда исполнения (целевая / типовая)                                    |
|----|-----------------------------------------------------------------------------|-------------------------------------|------------------------------------------------------------------------------|
| 9  | Маршрутизатор / L3-коммутатор периметра или ядра сети вуза                  | SEGMENTATION, маршрут в DMZ/VLAN БД | NOS (прошивка: тип/версия — уточнить на объекте, не выдумывать номер релиза) |
| 10 | ВМ/контейнерный хост резервного копирования (restic, pgBackRest, Bacula FD) | Бэкапы БД и конфигураций            | Linux (план: единая ОС для агента бэкапа и репозитория при self-hosted)      |

**Оценка состояния и достаточности:** в решении задачи 4 заложены 60 000 руб./год на «инфраструктуру и хостинг» — это соответствует типовому небольшому тарифу (одна–несколько ВМ или облачный пакет начального уровня). При принятых масштабах пользователей ДО такой класс ресурсов в целом согласуется с задачей при условии нормальной оптимизации запросов и контроля «тяжёлых» операций (большие файлы, отчёты без лимитов). Для declared SLA 99% и восстановления до 4 ч необходимы как минимум: мониторинг, резервирование на уровне гипервизора/облака, регулярные бэкапы и проверенные процедуры восстановления.

## 2.2. Программное обеспечение

- **Клиент:** React (веб), браузер на АРМ пользователей.
- **Сервер:** FastAPI, слой API, подсистема генерации документов (диаграммы взаимодействий).
- **Данные:** реляционная СУБД; конкретная СУБД в решении задачи 1 явно не названа — указано лишь «реляционная база данных».
- **Пользовательский контур:** Microsoft Excel на АРМ — входной артефакт импорта; учёт лицензий Office входит в ландшафт, даже если Excel не на сервере.
- **Инфраструктура (по материалам):** Docker упомянут в регламенте конфигураций (решение задачи 2); мониторинг и тикетирование описаны в решении задачи 3 и ITIL-текстах решения задачи 2; перезапуск/rollout относится к среде исполнения.

### Обеспечение лицензий:

- **Реестр ПО и лицензий** в службе эксплуатации (Service Desk / Excel-реестр на переходный период) с классами: ОС серверов и АРМ, СУБД, Office, ОС сетевого оборудования (подписка на обновления NOS), инструменты резервного копирования.
- **Периодическая инвентаризация** (не реже 1 раза в год) и сверка с фактом установки на ВМ/АРМ; ответственный со стороны вуза (ИТ/закупки).
- **Open-source стек** (Linux, nginx, Prometheus и т.д.) — контроль соответствия лицензий зависимостей в CI (SBOM по релизу).

Фактические номера договоров и ключи нужны от партнёра; до их получения раздел остаётся моделью, не результатом ревизии.

### 2.3. Сетевая инфраструктура

- **LAN:** пользователи ДО и администраторы работают из сети вуза; детальная сегментация VLAN, FW-правила, Zero Trust — не описаны.
- **Доступ извне вуза:** для операторов и администраторов, которым нужно вносить изменения или сопровождать систему вне офиса (например, из дома), целесообразно предусмотреть удалённый доступ только через корпоративный частный VPN (не «голый» RDP/SSH из интернета). Конкретная реализация VPN и политика сплит-туннелинга не заданы в учебных материалах и подлежат согласованию с ИБ ВГУ.
- **Сегментация (логическая по архитектуре):** из диаграммы вариантов использования следует разделение прикладного контура ДО и контура эксплуатации (мониторинг, CI/CD, тикеты — вне предметных вариантов использования). Рекомендуется целевая схема: DMZ или отдельный VLAN для API/прокси, закрытый VLAN для СУБД без прямого доступа с АРМ пользователей, отдельный канал админ-доступа (в т.ч. через VPN для внешних подключений); фактическая топология вуза не подтверждена без схемы сети.

## 3. Безопасность IT-инфраструктуры

### 3.1. Анализ рисков безопасности (не менее трёх вероятных угроз)

| Угроза                                                                                            | Вероятность (качеств.)                                                                                                                                                                                         | Потенциальный ущерб                                                                                                                                     |
|---------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Утечка или несанкционированная модификация персональных данных обучающихся (НПД в РФ)             | Средняя при отсутствии жёсткого RBAC, аудита и шифрования                                                                                                                                                      | Репутационный ущерб вуза, санкции регулятора, простой процессов при блокировке обработки ПДн                                                            |
| Компрометация учётной записи (фишинг, слабые пароли, отсутствие MFA у привилегированных ролей)    | Средняя                                                                                                                                                                                                        | Массовая выгрузка данных, подделка документов, инциденты в журнале                                                                                      |
| Инцидент при импорте.xlsx (вредоносное содержимое, поломанная кодировка, чрезмерный размер файла) | Низкая, при условии что на сервере реализованы очистка и безопасный разбор загрузок (извлечение данных без исполнения макросов, лимиты размера, контроль типов ячеек) — остаточный риск ошибок данных и отказа | Повреждение или неконсистентность данных, отказ импорта в срок, каскад ошибок в документах (диаграмма состояний связывает импорт с доменными статусами) |

|                                                                         |                                  |                                                                            |
|-------------------------------------------------------------------------|----------------------------------|----------------------------------------------------------------------------|
| Угроза                                                                  | Вероятность (качеств.)           | Потенциальный ущерб                                                        |
|                                                                         | в срок, а не «заражения» сервера |                                                                            |
| Ransomware / отказ сервиса на хостинге при недостаточном резервировании | Низкая–средняя                   | Нарушение SLA 99%, простой согласно решению задачи 1, срыв сроков приказов |

### 3.2. Существующие меры и их оценка

| Мера                                                                     | Что есть в материалах                                                       | Достаточно ли для угроз выше                                                                                                |
|--------------------------------------------------------------------------|-----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| RBAC, журнал критичных операций                                          | Диаграмма вариантов использования, регламент доступа решения задачи 2       | Частично — хорошо на бумаге; нужна проверка реализации и периодический аудит прав                                           |
| Мониторинг, алерты                                                       | Решение задачи 3, сценарий критического алерта на диаграммах взаимодействий | Частично — не заменяет защиту периметра и MFA                                                                               |
| Регламенты ITIL (инциденты, изменения, доступ)                           | Решение задачи 2                                                            | Повышают управляемость; не устраняют технические дыры без внедрения                                                         |
| Антивирус, МСЭ, брандмауэр, политика паролей, MFA, резервное копирование | Прямо не детализированы в решениях задач 1–4                                | Недостаточно данных — критический риск аудита: нельзя подтвердить эффективность без опроса заказчика и осмотра конфигураций |

**Базовая гипотеза для типового вуза (до осмотра):** на АРМ сотрудников действует антивирус/политика обновлений, на периметре — межсетевой экран, в Active Directory или аналоге — политика паролей; этого набора недостаточно для угроз с привилегированным доступом и ПДн без MFA, сегментации и проверяемых бэкапов. Гипотеза при осмотре подтверждается или опровергается; до аудита объекта вердикт по эффективности — условный.

### 3.3. Проблемы и риски

#### 3.3.1 Технические и организационные проблемы

1. **Single points of failure:** при отсутствии кластера БД и единственном инстансе приложения отказ одного хоста нарушает доступность.



2. **Перегрузка роли администратора ИС** — отмечено в решении задачи 2 (узкие места); совпадает с RACI, где администратор системы участвует во многих цепочках.
3. **Неопределённость размещения** (on-prem vs cloud) влияет на модель угроз и соответствие требованиям вуза к данным.

### 3.3.2. Масштабируемость

- стек React + API + РСУБД масштабируется горизонтально на уровне API при stateless-сессиях и вынесении файлов в object storage — это согласуется с диаграммами взаимодействий.
- Ограничение: генерация документов и тяжёлый импорт могут требовать фоновых воркеров и отдельных очередей; в представленных документах это указано как возможность, не как зафиксированная реализация.

### 3.3.3. Риски внедрения изменений

- Связка изменение шаблона ↔ данные ↔ импорт — высокий риск регрессий; смягчается САВ и регламентом изменений (решение задачи 2).
- Пессимистичный финсценарий в решении задачи 4: ROI может уйти в отрицательную зону при медленной адаптации пользователей.

## 4. Рекомендации

1. **Закрыть пробелы аудита:** получить акт инвентаризации серверов и АРМ, схему сети, политику ИБ, результаты последнего теста восстановления из бэкапа.
2. **Ввести минимальный набор ИБ для продуктива:** MFA для админов, шифрование канала (HTTPS обязательно), сегментация БД, антивирус/EDR на АРМ, регулярные обновления ОС и зависимостей приложения.
3. **Укрепить эксплуатацию:** разделить роли L1/L2 или ввести дежурства по календарю, чтобы снять перегруз с одного администратора (решение задачи 2).
4. **Инфраструктура под SLA:** целевое 99% требует измеримого MTTR и резервирования; пересмотреть бюджет строки «хостинг» при необходимости НА.
5. **Наблюдаемость:** формализовать стек (например Prometheus + Grafana + лог-агент) как **обязательный** артефакт релиза, не опцию.
6. **Данные:** политика сроков хранения ПДн, шифрование бэкапов, процедура DLP для выгрузок и сгенерированных приказов.

## 5. План внедрения / модернизации и управление проектом

### 5.1. Цели и задачи проекта

**Цель:** снизить трудозатраты и ошибки в администрировании ДО, обеспечить прозрачный контингент и ускорить подготовку распорядительных документов за счёт единого веб-сервиса.

**Задачи:**

- Ввести единую БД контингента, курсов и потоков с жизненным циклом статусов (диаграмма состояний).
- Реализовать контролируемый импорт xlsx с отчётом по строкам (диаграммы взаимодействий).
- Автоматизировать генерацию приказов/записок с шаблонами и аудитом (диаграмма вариантов использования).
- Ввести мониторинг и ITIL-процессы для соблюдения SLA (решение задачи 2, решение задачи 3).
- Обеспечить измеримый экономический эффект по модели TCO/ROI (решение задачи 4).

### 5.2. План проекта (не менее четырёх этапов с ориентировочными сроками)

| Этап                                    | Содержание                                                                                              | Примерный срок                                                                                                        |
|-----------------------------------------|---------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| 1. Аудит и проектирование               | Уточнение процессов, матрица ролей, нефункциональные требования, архитектура, модель угроз              | 4–6 недель                                                                                                            |
| 2. Разработка и тестирование            | Backend (FastAPI), frontend (React), СУБД, импорт, генерация документов, модульные/интеграционные тесты | 10–16 недель                                                                                                          |
| 3. Пилот и внедрение                    | Пилот на ограниченной группе, обучение, миграция данных, настройка мониторинга и регламентов            | 4–8 недель                                                                                                            |
| 4. Стандартная эксплуатация и улучшение | Сопровождение по ITIL, сбор метрик, плановые релизы, пересмотр SLA                                      | непрерывно; фаза стабильной эксплуатации с приёмкой эффекта по KPI — 12–24 мес после запуска (пересмотр SLA ежегодно) |

Сроки не дублируют точные календарные даты из учебной финмодели; они согласуются с порядком величин CAPEX/OPEX в решении задачи 4.

### 5.3. Управление рисками проекта (не менее трёх рисков и мер)

| Риск                                                                           | Смягчение                                                                           |
|--------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| Сопротивление пользователей / низкая дисциплина ввода                          | Программа обучения, суперпользователи в подразделении, UI-подсказки по шаблону.xlsx |
| Перерасход бюджета на доработках                                               | Change Advisory Board, бэклог приоритизации, «заморозка» scope на пилоте            |
| Недостижение экономии времени (как в пессимистичном сценарии решения задачи 4) | Ежемесячный контроль KPI, промежуточные измерения до/после, корректировка процессов |
| Технический: деградация при массовой генерации документов                      | Нагрузочное тестирование, очереди, ограничение размера пакетов                      |

### 5.4. Заинтересованные стороны и коммуникации

| Stakeholder                                       | Интерес                              | Каналы / частота                                           |
|---------------------------------------------------|--------------------------------------|------------------------------------------------------------|
| Руководитель подразделения ДО                     | Сроки наборов, корректность приказов | Еженедельный статус на внедрении; ежемесячный отчёт по KPI |
| Администратор ИС                                  | Доступность, инциденты, права        | Оперативные каналы при P1/P2; дашборды мониторинга         |
| Пользователи (сотрудники ДО)                      | Удобство, обучение                   | Сессии обучения, внутренняя wiki/инструкции по импорту     |
| Команда разработки/DevOps                         | RFC, релизы                          | Тикет-система, CI/CD, постмортемы по инцидентам            |
| Внутренний ИБ/юридический блок (если есть в вузе) | ПДн, согласия                        | Согласование модели обработки ПДн до прода                 |

## 6. Выводы

В ходе выполненной работы проведён комплексный аудит смоделированной ИТ-среды проекта партнёра (на примере ВГУ и подразделения дополнительного образования): описано предприятие и роль ИТ в процессах, построена логическая инвентаризация аппаратных и программных компонентов и контура сети, проанализированы основные угрозы и меры безопасности, сформулированы управляемые риски и приоритеты (устойчивость сервиса, импорт данных, эксплуатационная нагрузка на администратора). Сопоставлены принятые допущения по масштабу пользователей ДО и экономической

моделью проекта: архитектура «веб-приложение + СУБД + мониторинг и сервис эксплуатации» согласуется с задачей автоматизации при типичной нагрузке такого подразделения; для закрепления результата после запуска целесообразно включить в план внедрения нагрузочное тестирование и развитие наблюдаемости по уже заданным метрикам.

Подготовлены практические рекомендации по усилению ИБ, эксплуатации и управлению данными, а также план внедрения и модернизации с этапами, сроками, учётом заинтересованных сторон и мер смягчения проектных рисков. Документ задаёт единую основу для обсуждения с заказчиком и может дополняться уточнениями по мере появления конкретных сведений об объекте — это естественное развитие проекта, а не ограничение выполненного анализа.

Итог: выполненный аудит даёт целостную картину состояния смоделированной инфраструктуры и готовый каркас решений для успешного запуска и развития системы; реализовать его призваны разделы 4 и 5 настоящего отчёта.